

What is Crowdsourced Security?

[Crowdsourced security](#) is a type of offensive security that engages a global community of ID-verified security researchers to continuously identify, validate, and help mitigate vulnerabilities. These researchers use their cybersecurity experience to investigate systems, applications, or digital infrastructures for vulnerabilities that internal teams may not find.

These researchers are vetted and incentivized through platforms like [bug bounty programs](#), [vulnerability disclosure programs \(VDPs\)](#), and [pentest-as-a-service \(PTaaS\)](#).

In contrast, offensive security is a broad category of proactive tactics including penetration testing, red teaming, and vulnerability assessments. With crowdsourced security, these same methods are performed by third-party security researchers instead of, or in addition to, internal teams.

[In our latest research](#)*, 78% of Chief Information Security Officers (CISOs) already use crowdsourced security in their organization, and of those who don't, 86% plan to adopt it soon.

How Does Crowdsourced Security Work?

Finding success with crowdsourced security begins with defining the scope and goals of your program, then connecting with the community of security researchers. After launching the program, your organization will receive and review reports to address confirmed vulnerabilities. From there, you should refine or expand your program.

Here are the specific steps in more detail:

1. Define Scope and Goals

The process begins by clearly defining which assets are in scope for testing, such as web applications, APIs, or cloud infrastructure, and setting rules of engagement for what's off-limits. This stage also includes establishing objectives—whether the goal is to uncover critical vulnerabilities, meet compliance requirements, or maintain continuous coverage.

2. Choose the Right Program Type

Organizations then select the type of crowdsourced security program that best fits their needs. Common options include bug bounty programs that reward valid findings with payouts, [vulnerability disclosure programs \(VDPs\)](#) that offer a structured channel for receiving reports, and pentest-as-a-service (PTaaS) engagements for targeted, time-bound testing.

3. Recruit and Vet Security Researchers

Through a crowdsourced security platform, [vetted security researcher](#) with diverse skill sets are recruited to participate. Depending on the program, organizations can handpick researchers with expertise in specific domains such as cloud security, mobile applications, or AI systems.

4. Launch the Program

Once the scope, rules, and rewards are set, the program goes live. Researchers start testing according to the defined guidelines, applying real-world attacker techniques to uncover vulnerabilities and submit detailed reports.

5. Triage and Validate Submissions

Every submission is reviewed to verify accuracy, severity, and uniqueness. [Triage tools](#) or teams, often provided by the platform, filter out low-quality or duplicate reports and prioritize issues that pose the highest risk.

6. Remediate and Retest

Validated vulnerabilities are remediated by the organization's internal teams or external partners. Many programs also offer a retesting phase, where the same researchers confirm that fixes are effective and the issues are fully resolved.

7. Analyze and Report

The program's results are measured through analytics such as time to remediation, vulnerability trends, and financial risk reduction. These insights help demonstrate the program's value to stakeholders and guide improvements to security posture.

8. Iterate and Scale

Based on results, the program can be expanded to cover more assets, invite additional researchers, or increase reward tiers. Over time, crowdsourced security often evolves

from a single program into a core component of an organization's [broader offensive security strategy](#).

What are the Benefits of Crowdsourced Security?

Crowdsourced security methods offer several advantages over traditional tactics performed only by internal experts.

- **Access to Diverse, Global Talent**

Crowdsourced security taps into a worldwide [network of security researchers](#) with varied backgrounds and specialties, including experience with AI-model security and data privacy issues. This diversity means vulnerabilities are found from multiple perspectives, covering more ground than a single in-house team could.

*CISOs report identifying unknown vulnerabilities (59%) and supplementing internal security efforts (52%) as the top goals for their crowdsourced security programs.**

- **Simulates Real-World Attacks**

Unlike automated tools or checklist-based assessments, crowdsourced researchers think and act like real adversaries. They use creativity, novel attack chains, and non-standard techniques, making the testing more representative of actual threat scenarios.

- **Scalability and Flexibility**

Organizations can scale testing up or down as needed, adding or refining methods, whether for a quick, focused assessment or a [continuous, always-on vulnerability hunt](#). This flexibility supports both agile development cycles and long-term security programs, adapting to an organization's goals.

56% of CISOs use all three of the key crowdsourced security elements: bug bounty programs, VDPs, and third-party pentesting. Currently, just over half (57%) include data privacy and a third (33%) include AI systems in offensive security testing, but many have plans to include them in the next year.

- **Faster Discovery and Remediation**

With multiple researchers testing simultaneously, vulnerabilities are often found faster than in traditional security engagements. This speed shortens the window of exposure and allows teams to remediate before threats are exploited by actual malicious actors.

- **Quantifiable Security ROI**

Metrics like vulnerabilities found, mitigated losses by vulnerability type, and criticality levels are valuable in quantifying the investment compared to the cost of a proactive crowdsourced security program. [Return on Mitigation \(RoM\)](#) is a specific framework designed to help demonstrate the program’s tangible value to leadership and boards.

- **Aligns with Compliance Regulations and Best Practices**

Crowdsourced security supports regulatory and industry frameworks (e.g., NIS2, ISO 27001, PCI DSS) that require vulnerability management and disclosure processes, making it easier to meet both legal and best-practice standards.

How Does Crowdsourced Security Compare to Offensive Security?

Offensive security encompasses a wide range of proactive approaches, such as penetration testing, red teaming, and vulnerability assessments. In a crowdsourced security model, these activities are carried out by independent security researchers, either supplementing or replacing the work of in-house teams.

For those using crowdsourced security, the goals, available talent, and ideal use cases may differ from traditional offensive security.

Frequently asked questions

How does crowdsourced security work?	+
--------------------------------------	---

What are examples of crowdsourced security programs?	+
--	---

What are the benefits of crowdsourced security over traditional pentesting?	+
---	---

What are the risks or downsides of crowdsourced security?	+
---	---

How effective is crowdsourced security for large enterprises?	+
---	---

**Oxford Economics surveyed 400 CISOs from April to May of 2025. Respondents represented four countries (US, UK, Australia and Singapore) and 13 industries (Telecommunications, Real Estate/Construction, Utilities, Government/Public Sector, Consumer Goods, Education, Retail, Banking/Financial Services/Insurance, Retail/Ecommerce, Manufacturing, Healthcare, Transport/Logistics, and Not-for-profit/Non-profit). 70.5% of respondents worked at publicly-held organizations, while the other 29.5% worked for private organizations. Roughly 2 out of 5 respondents work at smaller organizations (between 1,000 and 2,500 employees); respondents from organizations with at least 10,000 FTEs make up 27% of the sample. Finally, revenue breakdowns are evenly split across 5 revenue buckets: Less than \$500m; \$501m to \$999m; \$1b to \$4.9b; \$5b to \$9.9b; and \$10b and more.*

Company

Knowledge

Resources

Leadership

Center

Blog

Careers

Application Security

Documentation

Partners

Penetration Testing

Leaderboard

Newsroom

Cloud Security

Partner Portal

Contact Us

Hacking

Resources

Cybersecurity

Attacks

DevSecOps

Contacted
by a
hacker? [+](#)